

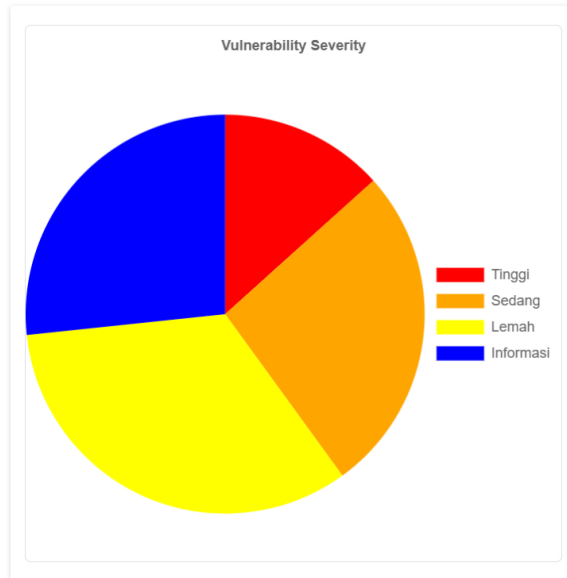
Generated on Sen, 20 Jul 2026 08:04:16

ZAP Version: 2.17.0

ZAP by [Checkmarx](#)

Most Severe Alert

High

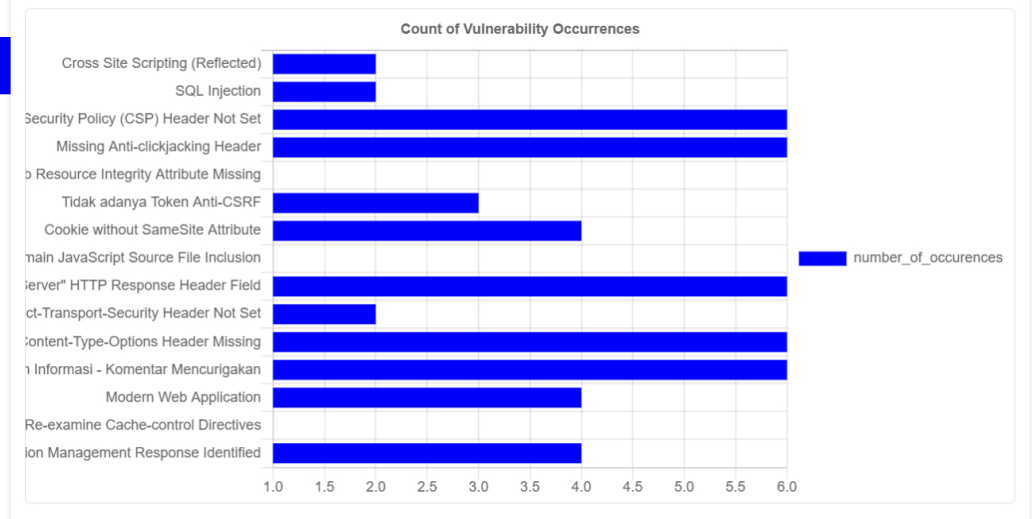


Report Description

- Laporan ini ditulis dan disusun oleh :
- Habib Muzakki (Habib)
- Alumni Kelas 12 Agama (jurusan Agama)
- Alumni MAN 2 KOTA SERANG
- Mahasiswa D4 Vokasi Teknik Informatika (Harkat Negeri Tegal)
- Si pemula Cyber Security dan Bug Hunter (Bug Bounty)

Most Common Bug

Content Security Policy (CSP) Header Not Set (6)



Insights

Level	Alasan	Site	Deskripsi	Statistic
Lemah	Peringatan		ZAP errors logged - see the zap.log file for details	1
Lemah	Peringatan		ZAP warnings logged - see the zap.log file for details	10
Lemah	Exceeded High	http://testfire.net	Percentage of slow responses	100 %
Info	Informasi	http://clients2.google.com	Percentage of responses with status code 2xx	100 %
Info	Informasi	http://clients2.google.com	Percentage of endpoints with content type application/json	100 %
Info	Informasi	http://clients2.google.com	Percentage of endpoints with method GET	100 %
Info	Informasi	http://clients2.google.com	Count of total endpoints	1
Info	Informasi	http://clients2.google.com	Percentage of slow responses	100 %
Info	Informasi	http://testfire.net	Percentage of responses with status code 2xx	50 %
Info	Informasi	http://testfire.net	Percentage of responses with status code 3xx	17 %

Info	Exceeded Low	http://testfire.net	Percentage of responses with status code 4xx	31 %
Info	Informasi	http://testfire.net	Percentage of responses with status code 5xx	1 %
Info	Informasi	http://testfire.net	Percentage of endpoints with content type application/javascript	2 %
Info	Informasi	http://testfire.net	Percentage of endpoints with content type application/pdf	1 %
Info	Informasi	http://testfire.net	Percentage of endpoints with content type application/x-shockwave-flash	1 %
Info	Informasi	http://testfire.net	Percentage of endpoints with content type image/gif	8 %
Info	Informasi	http://testfire.net	Percentage of endpoints with content type image/jpeg	28 %
Info	Informasi	http://testfire.net	Percentage of endpoints with content type image/png	2 %
Info	Informasi	http://testfire.net	Percentage of endpoints with content type text/css	2 %
Info	Informasi	http://testfire.net	Percentage of endpoints with content type text/html	50 %
Info	Informasi	http://testfire.net	Percentage of endpoints with method GET	96 %
Info	Informasi	http://testfire.net	Percentage of endpoints with method POST	3 %
Info	Informasi	http://testfire.net	Count of total endpoints	84
Info	Informasi	https://accounts.google.com	Percentage of responses with status code 2xx	100 %
Info	Informasi	https://accounts.google.com	Percentage of endpoints with content type application/binary	100 %
Info	Informasi	https://accounts.google.com	Percentage of endpoints with method POST	100 %
Info	Informasi	https://accounts.google.com	Count of total endpoints	1
Info	Informasi	https://testfire.net	Percentage of responses with status code 2xx	100 %
Info	Informasi	https://testfire.net	Percentage of endpoints with content type text/html	100 %
Info	Informasi	https://testfire.net	Percentage of endpoints with method GET	100 %
Info	Informasi	https://testfire.net	Count of total endpoints	1
Info	Informasi	https://testfire.net	Percentage of slow responses	100 %
Info	Informasi	https://www.google.com	Percentage of responses with status code 2xx	100 %
Info	Informasi	https://www.google.com	Percentage of endpoints with content type application/x-protobuf	100 %
Info	Informasi	https://www.google.com	Percentage of endpoints with method GET	100 %
Info	Informasi	https://www.google.com	Count of total endpoints	1
Info	Informasi	https://www.google.com	Percentage of slow responses	100 %
Info	Informasi	https://www.googleapis.com	Percentage of responses with status code 2xx	100 %
Info	Informasi	https://www.googleapis.com	Percentage of endpoints with content type application/json	100 %
Info	Informasi	https://www.googleapis.com	Percentage of endpoints with method POST	100 %
Info	Informasi	https://www.googleapis.com	Count of total endpoints	1
Info	Informasi	https://www.googleapis.com	Percentage of slow responses	100 %

Vulnerability Impact

#	Name	Impact
Cross Site Scripting (Reflected) [1] [2]	Cross-site Scripting (XSS) adalah sebuah teknik serangan yang melibatkan penyerang yang bergema disediakan misalnya kode ke browser pengguna. Browser misalnya dapat menjadi standar klient browser web, atau sebuah objek browser tertanam dalam produk perangkat lunak seperti browser hanya WinAmp,	

	aplikasi RSS reader, atau klien email. Kode itu sendiri biasanya ditulis dalam HTML/JavaScript, tetapi juga dapat memperpanjang untuk VBScript, ActiveX, Java, Flash, atau browser lain yang didukung teknologi.	
SQL Injection [1]	SQL injection may be possible.	
Content Security Policy (CSP) Header Not Set [1] [2] [3] [4] [5] [6] [7]	Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.	
Missing Anti-clickjacking Header [1]	The response does not protect against 'ClickJacking' attacks. It should include either Content-Security-Policy with 'frame-ancestors' directive or X-Frame-Options.	
Sub Resource Integrity Attribute Missing [1]	The integrity attribute is missing on a script or link tag served by an external server. The integrity tag prevents an attacker who have gained access to this server from injecting a malicious content.	
Tidak adanya Token Anti-CSRF [1] [2]	Tidak ada bukti Anti-CSRF yang ditemukan dalam formulir pengiriman HTML.	
Cookie without SameSite Attribute [1]	A cookie has been set without the SameSite attribute, which means that the cookie can be sent as a result of a 'cross-site' request. The SameSite attribute is an effective counter measure to cross-site request forgery, cross-site script inclusion, and timing attacks.	
Cross-Domain JavaScript Source File	The page includes one or more script files from a third-party domain.	

Inclusion		
Server Leaks Version Information via "Server" HTTP Response Header Field [1] [2] [3]	The web/application server is leaking version information via the "Server" HTTP response header. Access to such information may facilitate attackers identifying other vulnerabilities your web/application server is subject to.	
Strict-Transport-Security Header Not Set [1] [2] [3] [4] [5]	HTTP Strict Transport Security (HSTS) is a web security policy mechanism whereby a web server declares that complying user agents (such as a web browser) are to interact with it using only secure HTTPS connections (i.e. HTTP layered over TLS/SSL). HSTS is an IETF standards track protocol and is specified in RFC 6797.	
X-Content-Type-Options Header Missing [1] [2]	The Anti-MIME-Sniffing header X-Content-Type-Options was not set to 'nosniff'. This allows older versions of Internet Explorer and Chrome to perform MIME-sniffing on the response body, potentially causing the response body to be interpreted and displayed as a content type other than the declared content type. Current (early 2014) and legacy versions of Firefox will use the declared content type (if one is set), rather than performing MIME-sniffing.	
Keterbukaan Informasi - Komentar Mencurigakan	The response appears to contain suspicious comments which may help an attacker.	
Modern Web Application	The application appears to be a modern web application. If you need to explore it automatically then the Ajax Spider may well be more effective than the standard one.	
Re-examine Cache-control Directives [1] [2] [3]	The cache-control header has not been set properly or is missing, allowing the browser and proxies to cache content. For static assets like css, js, or image files this might be intended, however, the resources should be reviewed to ensure that no sensitive content will be cached.	
Session	The given response has been	

management Response Identified [1]	identified as containing a session management token. The 'Other Info' field contains a set of header tokens that can be used in the Header Based Session Management Method. If the request is in a context which has a Session Management Method set to "Auto-Detect" then this rule will change the session management to use the tokens identified.
--	--

Vulnerability Descriptions